MUSTER – fiktiver Fall mit erfundenen Daten. Dient nur zur Veranschaulichung.

Abschlussrapport OSINT-Ermittlung

Phishing gegen Kundenportal mit anschliessender Erpressung (Musterfall)

Fall	Stand	Sachbearbeitung
MUSTER-2026-001	12.11.2026, 09:09	MUS
Klassifizierung	**Fassung**	
MUSTER	pseudonymisiert	

Personen und Organisationen erscheinen als Platzhalter in eckigen Klammern, zum Beispiel [PERSON_01]. Die Zuordnung liegt ausschliesslich bei der fallführenden Stelle. Zeiten in Ortszeit (Europe/Zurich). Verweise wie `P-0007` führen zum Eintrag im Ermittlungsprotokoll.

---

1 Das Wichtigste in Kürze

Die Phishing-Seite, über die am 29.09.2026 Zugangsdaten der [ORG_01] abgegriffen wurden, lag auf einem gemieteten Server in den Niederlanden. Die Domain wurde drei Tage vor der Tat registriert. Derselbe Server lieferte die Phishing-E-Mail ein und ist das Ziel der angehängten Schadsoftware.

Die Anmeldung mit den erbeuteten Zugangsdaten kam über einen kommerziellen VPN-Dienst. Die Adresse führt deshalb nicht zu einem Anschlussinhaber. Die im Erpresserschreiben genannte Gruppe ist bekannt und betreibt die genannte Leak-Seite. Ein technischer Zusammenhang zwischen Phishing und Erpressung ist bisher nicht belegt.

- Phishing-Domain, Mailversand und Schadsoftware laufen auf demselben Server zusammen. ●●● hoch `B-01` `B-05` `B-06`
- Die Domain wurde eigens für die Tat eingerichtet. ●●● hoch `B-02`
- Die Anmelde-IP ist ein VPN-Ausgang und identifiziert keine Person. ●●○ mittel `B-04`
- Ob Phishing und Erpressung vom selben Täter stammen, ist offen. ●○○ tief `B-08`

---

2 Auftrag und Ausgangslage

Infrastruktur hinter der Phishing-Seite und der Anmeldung klären, die angehängte Datei einordnen und prüfen, ob ein Bezug zur im Erpresserschreiben genannten Gruppe besteht.

Eingangsdokument	PII-Prüfung	SHA-256
rapport_pseudonymisiert.md	sauber	`706533026dcb98b77330376bb019150c31391508278b6c895cc70b810a8c0cba`

3 Überblick in Zahlen

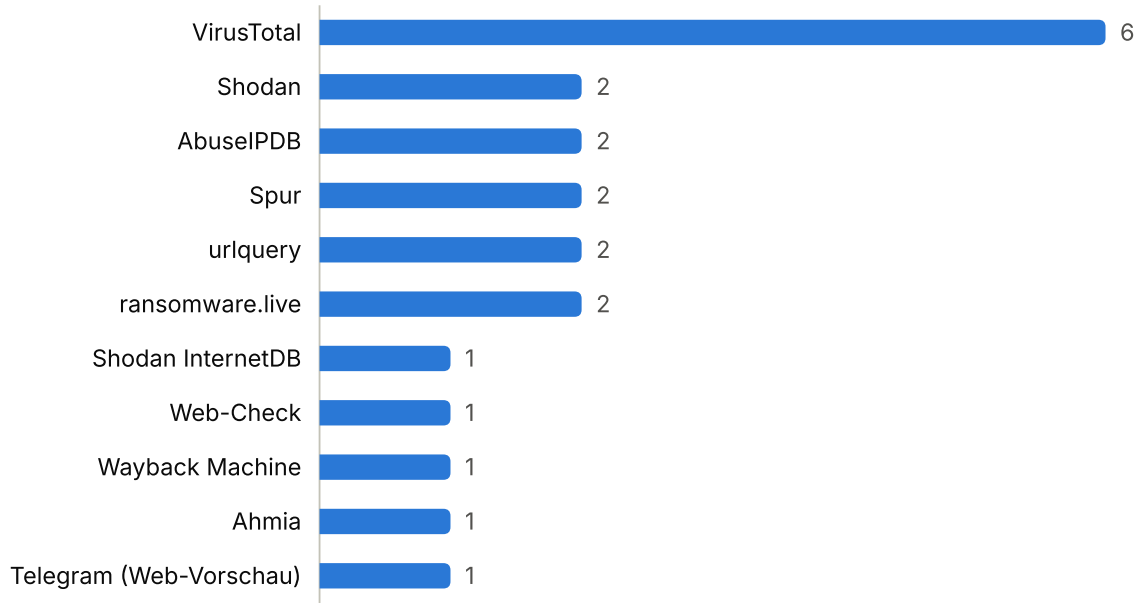
9	23	11	9
Indikatoren 5 bösartig, 4 verdächtig	Abfragen 1 ohne Treffer, 2 nicht ausgeführt	Quellen genutzt	Befunde 9 gegengeprüft



Indikatoren nach Bewertung. Die Bewertung jedes einzelnen Indikators steht in Abschnitt 5.

4 Vorgehen

Die Indikatoren aus den Eingangsdokumenten wurden über das OSINT-Gateway bei den unten aufgeführten Quellen abgefragt. Jede Abfrage ist mit Zeitpunkt, Ziel, Zweck und Prüfsumme der Antwort protokolliert, die Antworten liegen unverändert in der Fallakte. Die Befunde wurden von einer zweiten, unabhängigen Instanz anhand der Rohdaten gegengeprüft.



Verwertbare Abfragen je Quelle (mit und ohne Treffer). Einzelnachweis im Ermittlungsprotokoll.

Freigabe	Stand	Bedeutung
aktiv	nicht erteilt	Aktive Massnahmen: Das Ziel wird aufgerufen und kann das bemerken.
darkweb	nicht erteilt	Dark-Web-Recherche über Tor (Robin).
personenbezug	nicht erteilt	Abfragen zu Konten und Benutzernamen (Mastodon, Telegram).

5 Indikatoren

Nr.	Typ	Wert	Rolle und Herkunft	Bewertung	Belege

I-01	Domain	`kundenportal-sicher.example`	Phishing-Domain
			Herkunft: Rapport Ziff. 2
				● ! Bösartig
				VirusTotal 14/93
					`P-0011`
					`P-0013`
					`P-0015`

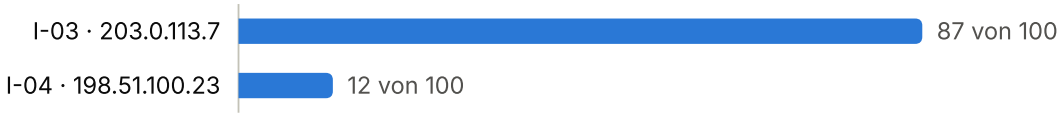
I-02	URL	`https://kundenportal-sicher.example/login`	Phishing-Seite Herkunft: Rapport Ziff. 2	● ! Bösartig	`P-0014` `P-0012`

I-03	IP	`203.0.113.7`	Server der Täter
			Herkunft: Rapport Ziff. 5
				● ! Bösartig
				AbuseIPDB 87/100; VirusTotal 9/93; Ports 22, 25, 80, 443
					`P-0001`
					`P-0002`
					`P-0003`
					`P-0004`

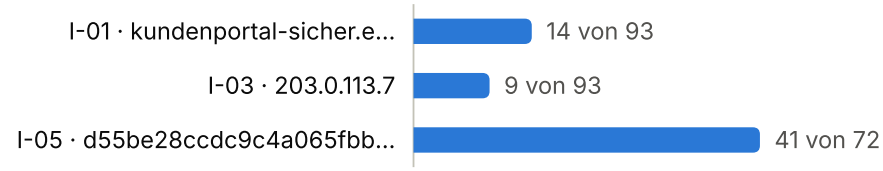
I-04	IP	`198.51.100.23`	Anmeldung mit erbeuteten Zugangsdaten
			Herkunft: Rapport Ziff. 3
				● ~ Verdächtig
				AbuseIPDB 12/100
					`P-0005`
					`P-0006`
					`P-0007`

I-05	Datei	`d55be28ccdc9c4a065fbbe7ee97d07e964faf02268afa64c47a046d95e3719f4`	Mailanhang Herkunft: Rapport Ziff. 4	● ! Bösartig VirusTotal 41/72	`P-0016` `P-0017`
I-06	E-Mail	`rechnung@kundenportal-sicher.example`	Absender der Phishing-Mail Herkunft: Rapport Ziff. 2	● ~ Verdächtig	`P-0011` `P-0010`
I-07	Gruppe	`MusterLocker`	Unterzeichner des Erpresserschreibens Herkunft: Rapport Ziff. 6	● ! Bösartig	`P-0020`
I-08	Onion	`o4zs5d56ycwedt5m3mx6etfbskmbh6vnsfqd7npwgik4e5bnmrdqaaad.onion`	Im Erpresserschreiben genannte Adresse Herkunft: Rapport Ziff. 6	● ~ Verdächtig	`P-0020` `P-0022`

I-09	Domain	`rechnung-portal.example`	Weitere Domain auf demselben Server Herkunft: Pivot aus P-0009 (frühere Namensauflösungen von I-03)	~ Verdächtig	`P-0009`



AbuseIPDB-Score je IP-Adresse (0 bis 100). Der Score beruht auf Missbrauchsmeldungen Dritter. Er zeigt, wie oft eine Adresse negativ auffiel, und ist ein Hinweis, kein Beweis.



VirusTotal: Zahl der Sicherheitsprodukte, die den Indikator als bösartig einstufen, von allen beteiligten Produkten. Wenige Treffer können Fehlalarme sein, viele übereinstimmende sind ein starkes Indiz.

6 Befunde im Einzelnen

B-01 · Die Phishing-Domain zeigt auf den Server 203.0.113.7

Der DNS-Eintrag der Domain kundenportal-sicher.example verweist auf 203.0.113.7. Der Server meldet unter dieser Adresse den Hostnamen der Domain und liefert auf Port 443 ein TLS-Zertifikat aus, das auf die Domain ausgestellt ist. Die DNS-Abfrage über die eigene Web-Check-Instanz bestätigt die Zuordnung.

> **Einfach erklärt:** Eine Domain ist wie ein Name im Telefonbuch, die IP-Adresse die Nummer dahinter. Drei voneinander unabhängige Stellen nennen für diesen Namen dieselbe Nummer. Die Phishing-Seite lag also auf diesem Server.

Feststellung | Sicherheit ●●● hoch | Quelle/Information B1 | ✓ Gegenprüfung: bestätigt

Indikatoren: `I-01` `I-03` Belege: `P-0011` `P-0001` `P-0010`

B-02 · Die Domain wurde drei Tage vor der Tat registriert

Die Domain wurde am 26.09.2026 registriert. Die erste Archivaufnahme der Anmeldeseite stammt vom 28.09.2026, die Phishing-E-Mail vom 29.09.2026. Der Sandbox-Dienst stuft die Domain als jünger als sieben Tage ein. Eine frühere, unverdächtige Nutzung ist nicht ersichtlich.

> **Einfach erklärt:** Die Internetadresse gab es vor der Tat praktisch nicht. Sie wurde kurz davor angelegt und sofort mit der gefälschten Anmeldeseite bestückt. Das spricht dafür, dass sie eigens für diesen Zweck eingerichtet wurde und nicht einer gehackten, sonst harmlosen Website gehört.

Bewertung | Sicherheit ●●● hoch | Quelle/Information B2 | ● ✓ Gegenprüfung: bestätigt

Indikatoren: `I-01` `I-02` Belege: `P-0011` `P-0015` `P-0014`

B-03 · Der Server steht bei einem Hosting-Anbieter und ist mehrfach als missbräuchlich gemeldet

203.0.113.7 gehört zum Netz der Beispiel Hosting AG (AS64500, Niederlande) und wird übereinstimmend als Rechenzentrumsadresse geführt, nicht als Anonymisierungsdienst. Bei AbuseIPDB liegen 64 Meldungen von 23 Meldern vor, Abuse-Score 87 von 100, zuletzt am 05.10.2026 wegen Phishing. Offen sind die Ports 22, 25, 80 und 443.

> **Einfach erklärt:** Der Server ist ein gemieteter Rechner in einem Rechenzentrum. Der Vermieter kennt seinen Kunden. Über ihn führt der direkteste Weg zum Betreiber. Der Server ist auch anderen schon negativ aufgefallen, was gegen einen Zufall spricht.

Feststellung | Sicherheit ●●● hoch | Quelle/Information B2 | ● ✓ Gegenprüfung: bestätigt

Indikatoren: `I-03` Belege: `P-0001` `P-0002` `P-0004` `P-0003`

B-04 · Die Anmelde-IP ist der Ausgang eines VPN-Dienstes

198.51.100.23 wird als Ausgangsknoten des VPN-Dienstes «BEISPIEL_VPN» geführt (anonymisierend, rund 214 beobachtete Geräte aus 31 Ländern). Offen sind die Ports 443 und 1194, wie für VPN-Knoten üblich. Missbrauchsmeldungen gibt es wenige (Score 12 von 100). Die Einstufung als VPN stammt von einem einzelnen Anbieter.

> **Einfach erklärt:** Wer über einen VPN-Dienst ins Internet geht, tritt nach aussen mit der Adresse des Dienstes auf, zusammen mit Hunderten anderer Kunden. Die Adresse aus dem Serverprotokoll gehört also dem VPN-Anbieter und nicht dem Täter. Eine Anfrage beim Anschlussanbieter würde ins Leere laufen.

Bewertung | Sicherheit ●●○ mittel | Quelle/Information B2 | ● ✓ Gegenprüfung: bestätigt

Indikatoren: `I-04` Belege: `P-0005` `P-0007` `P-0006`

B-05 · Der Mailanhang ist als Schadsoftware bekannt und kontaktiert denselben Server

41 von 72 Sicherheitsprodukten erkennen die Datei als bösartig, überwiegend als Trojaner der Familie «MusterStealer», einer Software zum Abgreifen gespeicherter Zugangsdaten. Die Datei wurde erstmals am 27.09.2026 bei VirusTotal eingereicht. Als kontaktierte Adresse ist 203.0.113.7 verzeichnet.

> **Einfach erklärt:** Die Datei tarnt sich als Rechnung, ist aber ein Programm, das auf dem Rechner gespeicherte Passwörter sammelt und an die Täter schickt. Sie meldet sich bei demselben Server, auf dem auch die gefälschte Anmeldeseite lag.

Feststellung | Sicherheit ●●○ mittel | Quelle/Information B2

🟡 ✓ Gegenprüfung: bestätigt mit Einschränkung

Zur Gegenprüfung: Die Zuordnung zur Familie beruht auf den Bezeichnungen der Scanner, nicht auf einer eigenen Analyse der Datei. Erkennungsrate und kontaktierte Adresse sind in den Rohdaten nachvollziehbar.

Indikatoren: `I-05` `I-03` Belege: `P-0016` `P-0017`

B-06 · Die Seite ahmt eine Anmeldemaske nach und sendet Eingaben an ein Sammelskript

Der Sandbox-Bericht vom 30.09.2026 zeigt eine Seite mit dem Titel «Kundenportal – Anmeldung». Das Formular sendet die Eingaben an /gate.php auf 203.0.113.7. Das Skript ist als Bestandteil eines bekannten Phishing-Baukastens erkannt. Bei VirusTotal lag zur genauen URL keine Analyse vor.

> **Einfach erklärt:** Die Seite sah aus wie das echte Kundenportal. Was dort eingetippt wurde, ging aber nicht an die [ORG_01], sondern an ein kleines Programm der Täter, das Benutzername und Passwort einsammelt.

Feststellung | Sicherheit ●●○ mittel | Quelle/Information B2 | 🟢 ✓ Gegenprüfung: bestätigt

Indikatoren: `I-02` `I-03` Belege: `P-0014` `P-0013` `P-0012`

B-07 · Die Gruppe MusterLocker ist bekannt und führt die genannte Onion-Adresse als Leak-Seite

ransomware.live führt eine Gruppe dieses Namens. Als deren Leak-Seite ist genau die Onion-Adresse verzeichnet, die im Erpresserschreiben steht. Die Gruppe nennt dort derzeit zwei Opfer, zuletzt am 12.09.2026. Die Onion-Adresse steht nicht auf der Sperrliste von Ahmia. Im Breach-Feed fand sich kein Hinweis auf die Phishing-Domain.

> **Einfach erklärt:** Die Absender des Erpresserschreibens verwenden den Namen und die Adresse einer Gruppe, die es tatsächlich gibt. Ob das Schreiben wirklich von dieser Gruppe stammt oder jemand nur deren Namen benutzt, lässt sich daraus nicht ablesen. Ob die [ORG_01] auf der Opferliste steht, muss im Haus mit dem echten Namen geprüft werden.

Feststellung | Sicherheit ●●○ mittel | Quelle/Information C2 | ● ✓ Gegenprüfung: bestätigt

Indikatoren: `I-07` `I-08` Belege: `P-0020` `P-0021` `P-0022` `P-0023`

B-08 · Phishing und Erpressung könnten vom selben Akteur stammen

Zwischen dem Abgriff der Zugangsdaten (29.09.2026) und dem Erpresserschreiben (01.10.2026) liegen zwei Tage. Ein technischer Zusammenhang ist nicht belegt: Weder der Server noch die Domains tauchen im Umfeld der Gruppe auf.

> **Einfach erklärt:** Es liegt nahe, dass dieselben Täter erst die Zugangsdaten gestohlen und dann erpresst haben. Bewiesen ist das nicht. Die zeitliche Nähe ist das einzige Indiz. Denkbar ist auch, dass die Zugangsdaten weiterverkauft wurden.

Hypothese | Sicherheit ●○○ tief | ● ✓ Gegenprüfung: bestätigt

Indikatoren: `I-03` `I-07` Belege: –

B-09 · Auf demselben Server lag eine zweite, ähnlich benannte Domain

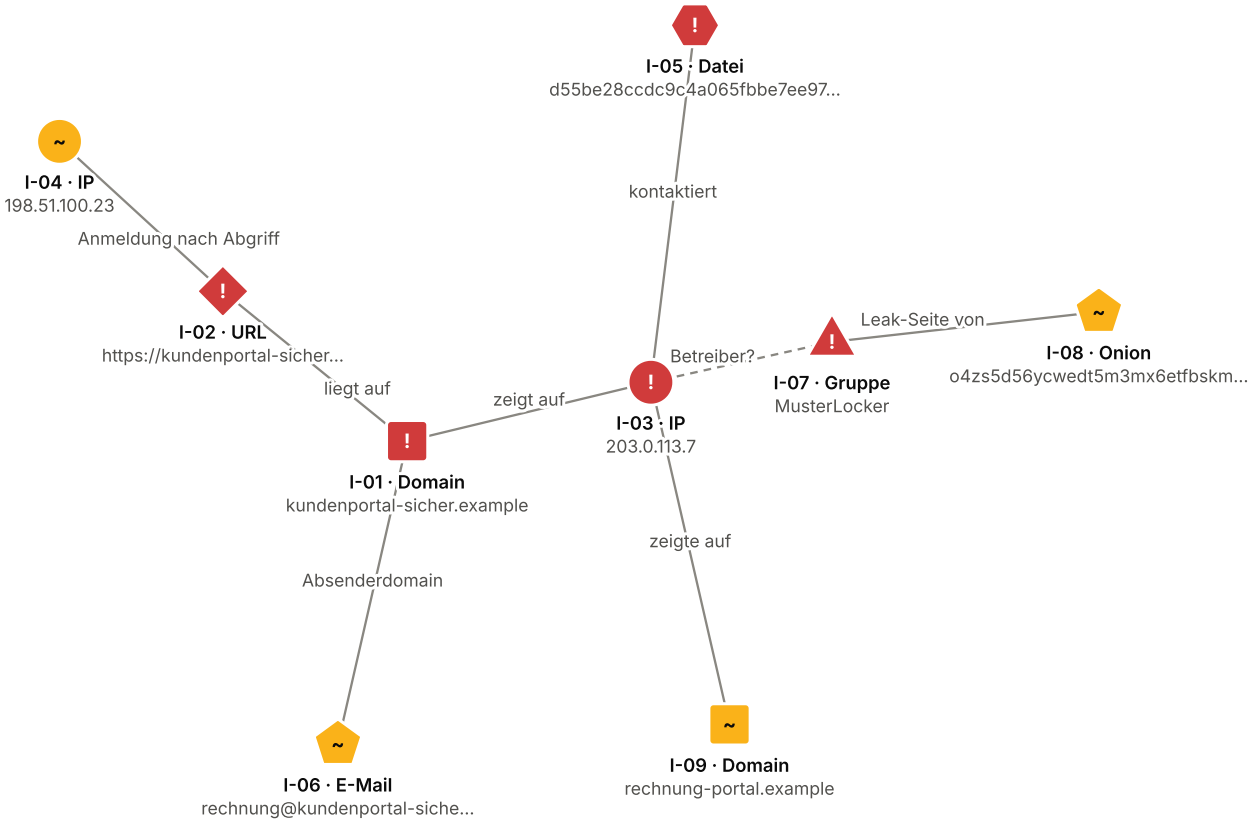
Laut den bei VirusTotal verzeichneten Namensauflösungen zeigte am 19.09.2026 auch die Domain rechnung-portal.example auf 203.0.113.7, eine Woche vor der Registrierung der Phishing-Domain.

> **Einfach erklärt:** Die Täter haben auf demselben Server vermutlich schon vorher eine ähnliche Falle betrieben. Das kann auf weitere Geschädigte hinweisen und ist ein zusätzlicher Ansatzpunkt beim Hosting-Anbieter.

Feststellung | Sicherheit ●●○ mittel | Quelle/Information B3 | ● ✓ Gegenprüfung: bestätigt

Indikatoren: `I-09` `I-03` Belege: `P-0009`

7 Zusammenhänge



● ! Bösartig ● ~ Verdächtig ▢ Domain ◇ URL ○ IP ⬡ Datei ⬠ E-Mail / Onion △ Gruppe

- - - unsichere Verbindung (Sicherheit tief)

Beziehungen zwischen den Indikatoren. Farbe und Zeichen zeigen die Bewertung, die Form den Typ. Jede Verbindung steht mit Beleg in der Tabelle darunter.

Von	Beziehung	Nach	Sicherheit	Belege
I-01 kundenportal-sicher.example	zeigt auf	I-03 203.0.113.7	●●● hoch	P-0011 P-0001
I-02 https://kundenportal-sicher.examp…	liegt auf	I-01 kundenportal-sicher.example	●●● hoch	P-0014
I-06 rechnung@kundenportal-sicher.exam…	Absenderdomain	I-01 kundenportal-sicher.example	●●○ mittel	Rapport Ziff. 2
I-05 d55be28ccdc9c4a065fbbe7ee97d07e96…	kontaktiert	I-03 203.0.113.7	●●○ mittel	P-0017

I-09 rechnung-portal.example	zeigte auf	I-03 203.0.113.7	●●○ mittel	P-0009
I-04 198.51.100.23	Anmeldung nach Abgriff	I-02 https://kundenportal-sicher.examp…	●●○ mittel	Rapport Ziff. 3
I-08 o4zs5d56ycwedt5m3mx6etfbskmbh6vns…	Leak-Seite von	I-07 MusterLocker	●●○ mittel	P-0020
I-07 MusterLocker	Betreiber?	I-03 203.0.113.7	●○○ tief	ohne Beleg (Hypothese)

8 Zeitachse

19.09.2026, 17:22	rechnung-portal.example zeigt auf den Server 203.0.113.7. P-0009
26.09.2026, 09:41	Registrierung der Domain kundenportal-sicher.example. P-0011
27.09.2026, 13:02	Die Schaddatei wird erstmals bei VirusTotal eingereicht. P-0016
28.09.2026, 12:15	Erste Archivaufnahme der gefälschten Anmeldeseite. P-0015
29.09.2026, 09:14	[PERSON_02] erhält die Phishing-E-Mail. Rapport Ziff. 2
29.09.2026, 09:31	Anmeldung am Kundenportal von 198.51.100.23 (VPN). Rapport Ziff. 3
30.09.2026, 08:18	Sandbox-Bericht von urlquery stuft die Seite als Phishing ein. P-0014
01.10.2026	Erpresserschreiben im Namen von «MusterLocker» trifft ein. Rapport Ziff. 6
02.10.2026	[PERSON_01] meldet den Vorfall. Rapport Ziff. 1
05.10.2026, 06:11	Jüngste Missbrauchsmeldung zum Server bei AbuseIPDB (Phishing). P-0002

9 Lücken und Grenzen

- Wer den Server gemietet hat, ist aus offenen Quellen nicht ersichtlich. Das weiss nur der Hosting-Anbieter.
- Hinter der Anmelde-IP steht ein VPN-Dienst. Ob er Verbindungsdaten führt, ist nicht bekannt.
- Der aktuelle Zustand der Phishing-Seite wurde nicht geprüft. Die Freigabe für aktive Massnahmen fehlte, eine Einreichung bei urlquery wurde deshalb abgelehnt (P-0019).
- Die Einzelmeldungen von AbuseIPDB waren wegen des Tageskontingents nicht abrufbar (P-0008). Die Zeitachse stützt sich auf die Kurzübersicht.

- Die Schaddatei wurde nicht selbst untersucht. Die Einordnung beruht auf den Angaben von VirusTotal.
- Ob die [ORG_01] auf der Leak-Seite genannt ist, liess sich nicht prüfen, weil ihr Name pseudonymisiert ist. Die Opferliste der Gruppe liegt in den Rohdaten (P-0021) und ist im Haus mit dem Klarnamen abzugleichen.
- Eine Recherche auf der Leak-Seite selbst fand nicht statt (Freigabe darkweb nicht erteilt).

Allgemein gilt: Offene Quellen zeigen, was Dritte beobachtet und gespeichert haben. Sie können veraltet, unvollständig oder falsch sein. Eine IP-Adresse oder ein Konto identifiziert für sich allein keine Person.

---

10 Empfehlungen

Priorität	Empfehlung
hoch	Editionsbegehren an die Beispiel Hosting AG zu Kundendaten, Zahlungsmitteln und Zugriffsprotokollen des Servers 203.0.113.7, über den Rechtshilfeweg.
hoch	Registrar um Sperrung von kundenportal-sicher.example und rechnung-portal.example ersuchen und Registrierungsdaten sichern.
hoch	Zugangsdaten des Kundenportals zurücksetzen und die Anmeldungen seit dem 29.09.2026 auswerten. Rechner von [PERSON_02] forensisch sichern, falls der Anhang geöffnet wurde.
mittel	Abklären, ob zu rechnung-portal.example weitere Anzeigen vorliegen.
mittel	Freigabe für aktive Massnahmen und Dark-Web-Recherche prüfen, um den Stand der Phishing-Seite und der Leak-Seite zu dokumentieren.
tief	Indikatoren (Anhang indikatoren.csv) an die zuständige Meldestelle und die IT-Sicherheit der [ORG_01] weitergeben.

Anhang A: Lesehilfe

Begriff	Bedeutung in diesem Rapport
Feststellung	Was eine Quelle unmittelbar zeigt. Beispiel: «Auf der IP ist Port 443 offen.»
Bewertung	Schluss aus einer oder mehreren Feststellungen. Beispiel: «Die Domain wurde eigens für die Tat registriert.»
Hypothese	Mögliche Erklärung, die noch nicht belegt ist. Gestrichelt umrandet.
Sicherheit hoch	Mindestens zwei voneinander unabhängige Quellen stimmen überein.
Sicherheit mittel	Eine zuverlässige Quelle, kein Widerspruch.
Sicherheit tief	Einzelhinweis, unbestätigt oder mit Widersprüchen.

Quelle/Information (z. B. B2)	Buchstabe: Zuverlässigkeit der Quelle von A (zuverlässig) bis F (nicht beurteilbar). Ziffer: Glaubhaftigkeit der Information von 1 (bestätigt) bis 6 (nicht beurteilbar).
Gegenprüfung	Eine zweite Instanz ohne Kenntnis des Ermittlungsverlaufs hat den Befund anhand der Rohdaten nachvollzogen.

Anhang B: Glossar

Begriff	Erklärung
Abuse-Score	Kennzahl von AbuseIPDB von 0 bis 100. Je höher, desto häufiger und aktueller wurde eine IP-Adresse als missbräuchlich gemeldet.
AS / ASN	Autonomes System: das Netz eines Anbieters. Die Nummer zeigt, wem ein Adressbereich gehört.
Hash (SHA-256)	Digitaler Fingerabdruck einer Datei. Gleicher Hash bedeutet gleiche Datei, unabhängig vom Dateinamen.
Infostealer	Schadsoftware, die gespeicherte Passwörter, Sitzungsdaten und Ähnliches vom Rechner sammelt und an die Täter schickt.
Leak-Seite	Website einer Erpressergruppe, auf der sie Opfer nennt und gestohlene Daten veröffentlicht, um Druck aufzubauen.
Onion-Adresse	Adresse einer Website im Tor-Netz. Betreiber und Standort des Servers sind dabei verschleiert.
Phishing	Täuschung mit nachgebauten Websites oder E-Mails, um Zugangsdaten zu erbeuten.
Sandbox	Abgeschottete Umgebung, in der eine verdächtige Seite oder Datei gefahrlos geöffnet und beobachtet wird.
TLS-Zertifikat	Digitaler Ausweis einer Website für verschlüsselte Verbindungen. Er nennt, für welchen Namen er ausgestellt wurde.
VPN	Dienst, der den Datenverkehr über eigene Server umleitet. Nach aussen ist nur die Adresse des Dienstes sichtbar.

Anhang C: Nachvollziehbarkeit

Das Abfrageprotokoll umfasst 23 Einträge des Gateways. Verkettung und Rohdaten wurden bei der Erstellung dieses Rapports geprüft und sind unverändert.

Letzter Kettenwert: `d05df1358a8e85db02a0a99eb43a30eafcc875cd3b8bf7f8f68ad3df107d0077`
Prüfsumme befunde.json: `c458ba5e864e7166453dbea3d5430dec7cfb8381de599ca0281c7e90c05c080a`

Einzelnachweis aller Abfragen: Ermittlungsprotokoll.html. Prüfung jederzeit wiederholbar mit `python3 tools/audit_pruefen.py MUSTER-2026-001`.

Erstellt am 12.11.2026, 09:09 aus befunde.json und dem Abfrageprotokoll der Fallakte. Die Aussagen stützen sich auf offene Quellen und sind vor einer Verwendung im Verfahren durch die fallführende Stelle zu würdigen.